

AZTHREUS SYSTEMS: IT SECURITY, DATA GOVERNANCE & ACCEPTABLE USE

Document ID: AZ-CONSOLIDATED-02 | **Classification:** Internal/Confidential **Owner:** CISO | **Review Cycle:** Annual **Jurisdictions:** Philippines, United States, all access locations

1. PURPOSE & SCOPE

A compromised workstation, weak passphrase, or misclassified data is not merely an IT inconvenience — it is a potential vector for mission failure or loss of life. This policy integrates IT security baselines, data classification/governance, and acceptable use rules. It applies to all employees, contractors, vendors, and all devices (company-owned or BYOD) accessing Azthreus systems, networks, or data, regardless of physical location.

Related Policies: AZ-DATA-001 (classification), AZ-HR-005 (remote work security), AZ-HR-002 (onboarding provisioning), AZ-ENG-001 (secure coding), AZ-RISK-001 (risk escalation), Volume 2 Part 13 (incident response). Where conflicts exist, the more restrictive requirement applies.

2. DATA CLASSIFICATION & GOVERNANCE

2.1 Classification Levels

Level	Label	Description	Examples
L1	Public	Intentionally public; no impact from disclosure	Published papers, press releases, open standards docs
L2	Internal	Internal use only; minor reputational/operational harm	Process documentation, meeting notes, training materials
L3	Confidential	Significant harm from disclosure; commercially sensitive, personal data, unclassified technical project data	Unreleased source code, salary/HR records, customer contracts, financial projections
L4	Mission-Critical / Restricted	Could endanger life, compromise active missions, violate ITAR/EAR/national security	Flight software, cryptographic keys, command auth sequences, classified contract data

Labels: Document headers/footers (PUBLIC / INTERNAL / CONFIDENTIAL / MISSION-CRITICAL – RESTRICTED). File prefixes: `pub_`, `int_`, `conf_`, `mcr_`. Physical documents labeled on every page. When in doubt, assign higher level.

Responsibilities: Data Creators classify at creation. Data Owners (team leads/managers) accountable for ongoing correctness and lifecycle. CISO reviews annually. Reclassification requires CISO approval.

2.2 Data Handling by Level

Action	L1 (Public)	L2 (Internal)	L3 (Confidential)	L4 (Mission-Critical)
Store on personal device	Yes	MDM only	No	No
Send via corporate email	Yes	Yes	Yes (encrypted)	No
Send externally	Yes	Manager approval	CISO approval	Prohibited
Share with contractor	Yes	Manager approval	CISO + NDA	Security Office
Print	Yes	Yes	Justified only	Controlled copies, numbered/logged
Dispose (digital)	Delete	Secure wipe (DoD/NIST)	Crypto erase + shred	Certified destruction
Dispose (paper)	Recycle	Cross-cut shred	Secure shred bin	NSA-grade particle shredding
Rest/Transit Encryption	None	None required	AES-256 + TLS 1.3	PQ crypto (if lifecycle >2030)

Level 3 Specific: Need-to-know access. External sharing requires Data Owner + CISO written approval. No personal devices (even MDM). Physical docs in locked cabinets, not left unattended. Printing requires justification. USB drives must be encrypted and IT Security-approved.

Level 4 Specific: Personnel must have confirmed clearance. Zero Trust + RBAC + MFA. Just-in-time access provisioning (auto-revoked at session end). Stored in SCIFs where applicable (Volume 2 Part 10). External network transmission prohibited without approved encrypted tunnel + CISO sign-off. Any suspected disclosure reported to CISO within 1 hour.

[EXPANDED]

2.2.1 Cryptographic Key Management (L4 Data)

All cryptographic keys protecting L4 (Mission-Critical/Restricted) data must follow the procedures below. This section supplements the general L4 handling rules above with specific key lifecycle requirements.

A. Key Classification

Key Type	Description	Examples	Minimum Key Length	Rotation Frequency
Flight Command Keys	Authenticate uplink commands to spacecraft	Command auth signing keys, session keys	ML-DSA-87 (PQC) or ECDSA P-384	Every launch / every 90 days whichever is sooner
Telemetry Encryption Keys	Encrypt downlink telemetry streams	AES-256-GCM symmetric keys	AES-256	Every 30 days
Mission Data at Rest Keys	Encrypt stored mission data	Volume encryption keys, file-level keys	AES-256-GCM or ChaCha20-Poly1305	Annually or on personnel change
Ground Station TLS Keys	Secure ground-to-ground comms	TLS server/client certificates	Ed25519 or ML-DSA-65 (PQC)	Annually
Key Management System (KMS) Root Keys	Anchor all other keys	Root CA keys, master encryption keys	ML-KEM-1024 (PQC) + RSA-4096 (hybrid, transitional)	Every 5 years or on compromise
Humanity Archive Preservation Keys	Ensure long-term archive integrity	Archive signing keys, fixity check keys	ML-DSA-87 + SHA-384 hash	Every 10 years (archive scope)

B. Key Ceremony Procedure

A **Key Ceremony** is a formal, audited procedure for generating root keys and master keys. It must be conducted for: initial KMS deployment, root key rotation, KMS recovery from compromise, or generation of any new master key class.

Participants (minimum required): | Role | Purpose | |—|—| | CISO (or designated Key Custodian) | Ceremony authority and oversight | | 2 Key Custodians (non-CISO) | Share-holders for Shamir Secret Sharing (see below) | | Systems Architect | Technical implementation verification | | Independent Witness (Legal Officer or designee) | Procedural compliance observation | | Scribe (IT Security staff) | Ceremony documentation and logging |

Ceremony Steps: 1. **Pre-Ceremony (T-5 business days):** Verify hardware RNG or approved DRBG seeding material. Confirm ceremony environment (SCIF or hardened room) is physically secured. Distribute ceremony agenda and participants list. Confirm no single participant holds more than one Shamir share. 2. **Generation (T-0):** Hardware Security Module (HSM) or approved key generation tool invoked. Key material generated from entropy source verified by independent test. Participants observe generation process. 3. **Secret Sharing (T+30 min):** Root key split using Shamir Secret Sharing (see below). Each share written to separate physical medium (USB security key or smart card). Each share verified by reading back to share-holder. 4. **Verification (T+60 min):** Generated key verified against test vector or functional test (encrypt/decrypt). Key material backed up to secondary HSM or secure vault. 5. **Documentation (T+90 min):** Ceremony record completed: date/time, participants, key ID, algorithm, length, ceremony log, split parameters, share distribution record. All participants sign ceremony record. Record classified L4 and stored in secure document system. 6. **Post-Ceremony:** Ceremony video recording (if HSM supports) archived L4. Old keys placed on revocation list with sunset date.

C. Shamir Secret Sharing Requirement

All KMS root keys and flight command keys must use **Shamir Secret Sharing (SSS)** with the following parameters:

Parameter	Requirement
Threshold (t)	2-of-3 (minimum); 3-of-5 for keys protecting >10 active missions
Total shares (n)	3 (standard); 5 (multi-mission)
Share distribution	Each share held by a separate Key Custodian. No custodian may hold shares for multiple key classes simultaneously.
Share storage	Physical medium (HSM smart card or USB security key) stored in: (a) Key Custodian's personal fireproof safe (off-site), or (b) Azthreus secure vault (on-site), or (c) bank safety deposit box (off-site).
Share verification	Annual verification that all shares are intact and custodians are still employed/cleared. Quarterly for flight command keys.
Emergency reconstruction	At least 3 custodians must be reachable within 4 hours for emergency key reconstruction. Emergency contact list maintained by CISO and updated quarterly.
Custodian change	When a Key Custodian departs or is reassigned, their share is destroyed and new share generated to remaining custodians before new share issued to replacement custodian. Ceremony record updated.

D. Key Rotation Schedule

Key Type	Maximum Lifetime	Rotation Trigger	Method
KMS Root Keys	5 years	Scheduled rotation; immediate on suspected compromise	Full Key Ceremony (§B above)
Flight Command Keys	90 days or per-launch (whichever sooner)	Launch event; personnel change in command chain; suspected compromise	New key generated in HSM; old key revoked; spacecraft receives new key via encrypted uplink
Telemetry Encryption Keys	30 days	Scheduled rotation; personnel change; suspected compromise	Automated rotation via KMS; old key archived then destroyed after 90-day retention
Mission Data at Rest Keys	1 year	Annual rotation; personnel change with key access; suspected compromise	Re-encrypt data with new key; destroy old key after verification
Ground Station TLS	1 year	Certificate expiry; personnel change with server access	Certificate renewal via internal or external CA; old cert revoked
Humanity Archive Keys	10 years	Decennial rotation; compromise of any signing key	New key generated; archive re-signed with new key; old key archived

E. Key Revocation and Compromise Response

1. **Immediate Revocation (within 1 hour):** Suspected or confirmed compromise of any L4 key triggers immediate revocation. Affected systems switched to backup key or degraded-safe mode.
2. **Investigation (within 24 hours):** CISO initiates formal investigation per AZ-RISK-001. Scope: how compromise occurred, what data/systems were exposed, whether mission impact occurred.
3. **Key Replacement (within SLA for key type):** New key generated per rotation schedule above. All systems updated. Compromised key permanently destroyed (crypto-erase + physical destruction of media).
4. **Notification:** Affected mission owners notified within 4 hours. Executive Board notified within 24 hours if flight systems affected. Government partners notified per contract terms if classified data affected.
5. **Post-Incident Review:** Formal lessons-learned within 2 weeks. Findings feed into improved physical security, access controls, or ceremony procedures.

F. Key Destruction

Key Type	Destruction Method	Authorization Required
Symmetric keys (AES, ChaCha)	Crypto-erase (overwrite with random then zeroize)	CISO approval
Asymmetric key pairs (private key)	Crypto-erase + physical media destruction (shred smart card/USB)	CISO + 1 Key Custodian
HSM-stored keys	HSM key slot zeroization command	CISO + Systems Architect verification
Archive signing keys	Destroyed only after archive re-signed with new key; crypto-erase + physical media destruction	CISO + Legal Officer (retention verification)

All key destruction events logged in Key Management System with: Key ID, destruction date, method, authorizer, witness. Destruction records retained for key validity period + 10 years.

2.3 Data Lifecycle

Creation: Classify and label at creation. Automated data (telemetry, logs) embed label in header/metadata at generation. **Retention Minimums:** Mission telemetry (active) → mission duration + 10y | Mission telemetry (completed) → 50y | Released source code → indefinite (Humanity Archive) | Unreleased/prototype source code → 7y | Security incident logs → 7y | HR records → employment + 7y | Cryptographic key logs → key validity + 10y | Financial records → 10y | Visitor logs → 10y | Command uplink logs → indefinite (immutable ledger) | Routine

email/comms → 3y | ADRs → indefinite. **Transfer:** Classification must be preserved. All L3/L4 transfers logged (sender, receiver, description, date/time, method). No transfers to jurisdictions prohibited by export control (Procedure 18.1.1.1). **Disposal:** Only after retention period elapsed and no active legal holds. Methods per table above. Certificate of Destruction required for all L4 disposal.

2.4 Personal Data & Privacy

All personal data classified at L3 minimum. Information that could endanger an individual (clearance status, psychological evaluations) classified at L4. Data minimization: only minimum personal data for defined purpose collected/retained. Data subject rights (where applicable): know what is held, request correction, request deletion. Respond within 30 calendar days. Requests directed to Legal & Compliance Officer.

2.5 Data Governance Roles

Role	Responsibilities
Data Owner	Accountable for classification, access controls, lifecycle, external sharing approvals
Data Custodian	Technical implementation of storage/backup/access controls (IT/Infrastructure)
Data User	Follow policy when handling data within authorized scope
CISO	Sets/enforces policy, conducts annual classification audits, approves exceptions
Legal & Compliance Officer	Advises on legal obligations, manages data subject rights and breach notifications

Data Governance Committee: Meets quarterly (CISO chair, Legal Officer, HR Director, Engineering Lead, Mission Ops rep). Reviews: classification audit findings, regulatory changes, exception requests, breach post-mortems.

2.6 Annual Classification Audit

CISO samples ≥10% of stored data assets annually to verify: correct classification, matching access controls, retention periods observed, certified disposal records. Findings reported to Data Governance Committee and Executive Board.

2.7 Policy Exceptions

Written request to CISO documenting: specific deviation, business/operational justification, duration, compensating controls. CISO may approve, conditionally approve, or reject. Logged and reviewed at next Data Governance Committee.

3. DEVICE SECURITY REQUIREMENTS

3.1 Company-Owned Devices

Control	Requirement
Full-Disk Encryption	AES-256 or NIST-approved, mandatory all endpoints
EDR Agent	Approved agent installed, active, reporting. Disabling prohibited.
OS Patching	Critical: 72h. Standard: 14 days.
Screen Lock	Auto-activate after max 5 min inactivity
Firewall	Host-based firewall active at all times
MDM/Remote Wipe	All mobile devices and laptops enrolled in approved MDM
Antivirus/Anti-Malware	Active and updated alongside EDR
Secure Boot	Enabled where supported

Report any non-functional baseline control to IT immediately. Do not use device for work until restored.

3.2 BYOD (Personally Owned Devices)

Permitted for limited use (email, messaging, HR portal) with conditions: Approved MDM profile installed (remote wipe of company data only, no personal data access). Full-disk encryption + 5-min screen lock. **Must not** access mission-critical repos, L2+ classified data, or active flight ops. Must not be shared with family without ensuring company data is inaccessible. Lost/stolen: report to IT within 2 hours for remote wipe.

3.3 Prohibited Device Activities

Disabling/circumventing security controls. Installing unauthorized software. Connecting to untrusted Wi-Fi without company VPN. Using personal cloud storage (Google Drive, Dropbox, iCloud) for work files. Connecting unapproved USB drives to devices with L2+ data (L1 USB

requires manager approval + encrypted devices). Exposing screens to unauthorized observation in public when handling Confidential+ data.

4. AUTHENTICATION & ACCESS CONTROL

4.1 Password/Passphrase Policy

Requirement	Standard
Min passphrase length	20 characters (preferred)
Min random password length	16 characters
Password manager	Mandatory — approved tool only. Writing passwords on paper or in unencrypted files prohibited.
Reuse	No cross-account or work↔personal reuse
Sharing	Never, including with IT. IT will never request a password.
Changes	Immediately on suspicion of compromise. No forced periodic rotation unless compromise suspected.

4.2 Multi-Factor Authentication (MFA)

Mandatory for all accounts without exception (email, VCS, messaging, HR portal, cloud/SaaS, VPN, admin/privileged). Acceptable methods (in preference order): 1) Hardware security key (FIDO2/WebAuthn) — required for privileged accounts and Mission-Critical access. 2) Authenticator app (TOTP, CISO-approved list). 3) Push notification via approved authenticator app. **SMS-based OTP is NOT acceptable** (SIM-swapping risk). Exceptions require written CISO approval and are time-limited. Lost MFA device: contact IT immediately — recovery requires Security Office identity verification (not email alone).

4.3 Privileged & Shared Accounts

Privileged accounts (admin, root, DBA, deployment): Must not be used for routine daily tasks — separate standard account for email/browsing/general work. Hardware security key MFA required. All activity logged and reviewed by CISO. Shared service accounts: require explicit CISO approval, documented in Privileged Access Register, reviewed quarterly. Individual accountability via session logging. Least-privilege basis. Reviewed annually and on role change.

4.4 Access Provisioning & De-Provisioning

New employee access: IT provisions per RBAC (Procedure 7.1.1) based on HR role designation.

Role change: IT notified within 5 working days. **Separation (resignation/termination/contract**

end): All access revoked within 4 hours of last working moment. HR responsible for notifying IT of date/time. Extended leave (4+ weeks): non-essential system access suspended, reinstated at return-to-work.

5. NETWORK & CONNECTIVITY

5.1 VPN Requirements

All remote access to internal systems requires company-approved VPN. No split-tunneling that bypasses network monitoring. Required for: internal repos, internal tools/dashboards/admin systems, any system handling L2+ data.

5.2 Public/Untrusted Wi-Fi

Connect company VPN before accessing any work system. Avoid handling Confidential/Mission-Critical data where screen can be observed. Never connect to networks requiring unknown certificates or presenting certificate warnings. If secure connection unavailable, defer Confidential+ work.

5.3 Home Network Security

Firmware kept up to date. Default router passwords changed. Separate guest network for IoT/personal devices recommended. Public DNS without DNS-over-HTTPS discouraged. No company-conducted home audits, but IT offers guidance.

6. ACCEPTABLE USE

6.1 General Principles

Limited personal use permitted, provided it does not: interfere with work performance, consume excessive bandwidth/storage, violate policy or law, create security risk or liability exposure. Privilege, not right — may be revoked.

6.2 Prohibited Uses

Data/Confidentiality: Accessing/copying/transmitting data above authorized level. Transmitting Confidential/Mission-Critical data over unencrypted channels. Storing work data in personal cloud or unencrypted personal devices. **Software/Code:** Unlicensed software. Malicious code or unauthorized scripts. Personal commercial development using company systems. Circumventing code review or CI/CD security gates. **Communications:** Spam, unauthorized phishing, harassment. Representing personal views as official company positions (see AZ-COMMS-001). Political advocacy/solicitation. **Access/Identity:** Unauthorized system/account/data access (even out of curiosity). Using another's credentials. Privilege escalation attempts. **Content:** Illegal content. Content violating Code of Conduct (discriminatory, harassing, sexually explicit).

6.3 Monitoring & Privacy

No expectation of privacy on company systems/devices/networks for any purpose. Company reserves right to monitor: network traffic, company device activity, email/messaging content, system access logs. Monitoring data restricted to CISO, authorized Security team, Legal Officer. Not used for performance evaluation except in security investigations. Philippines: complies with Data Privacy Act 2012 (RA 10173). US: complies with federal/state electronic monitoring laws. Disclosed in this policy and acknowledged in onboarding.

7. SECURITY INCIDENT REPORTING

7.1 What Constitutes a Security Incident

Suspected unauthorized access. Loss/theft of work device. Malware/ransomware discovery. Phishing/social engineering (even if not responded to). Accidental L3/L4 data disclosure. Unpatched vulnerability discovery. Anomalous repo/CI/CD/production system behavior. Any situation where this policy may have been violated. **Standard: if unsure, report it.**

7.2 How to Report

Channel	Use For
CIRT Hotline (24/7)	Active incidents, suspected breaches, lost/stolen devices
CISO direct email	Non-urgent security concerns, policy questions, suspected vulnerabilities
IT Help Desk ticket	Device security issues, access anomalies
Ethics Hotline (anonymous)	Policy violations by others, concerns about CISO/IT conduct

7.3 Non-Retaliation

No retaliation for good-faith security reporting. Retaliation against a security reporter is itself a serious disciplinary matter under AZ-HR-006.

7.4 Incident Response Process

CIRT follows Volume 2 Part 13 procedures. Reporting employee informed of outcome to extent permitted by investigation. External incident communications governed by AZ-COMMS-001 Section 4.4.

8. THIRD-PARTY & VENDOR ACCESS

Requirements: Complete Third-Party Security Assessment before access. Sign NDA + Export Control Acknowledgment. Provisioned with minimum access (CISO-approved). Access L4 data requires COO + CISO co-authorization. Access revoked immediately on contract completion.

Remote Vendor Sessions: Supervised by Azthreus employee throughout. Approved remote access mechanism only (no ad hoc tools). Logged and recorded. Terminated immediately on completion. No persistent remote access credentials — each session requires new authorization.

9. SECURITY TRAINING

Training	Frequency	Audience
Security Awareness Fundamentals	On hire, then annual	All employees
Phishing Simulation Exercises	Quarterly	All employees
ITAR/EAR Compliance Training	On hire, then annual	All employees
Privileged Access Security Training	On hire + on privilege grant	Privileged access holders
Incident Response Drill	Annual	CIRT, Mission Controllers, Senior Engineers
Data Classification & Handling	On hire	All with data access

Training tracked in HR portal; counts toward 40-hour CPE requirement (AZ-HR-007). Failure to complete without documented extenuating circumstances = policy violation.

9.1 Security Culture Expectations

Security is everyone's responsibility: challenge unknowns in secure areas, no tailgating, report suspicious emails even without clicking, lock screens when stepping away, speak up when observing policy violations.

10. ENFORCEMENT

Violations subject to AZ-HR-006 disciplinary action (written warning → termination). Factors: intentional v. negligent, actual exposure/compromise/mission impact, self-reporting (significant mitigating factor), prior violations. Criminal violations (unauthorized computer access, export control breaches) referred to authorities. Policy reviewed annually by CISO with Legal, IT, and Engineering Lead input. Earlier review triggered by: significant security incident, material threat landscape change, legal/regulatory change, external audit recommendation. Employees notified of material updates via internal messaging; must re-acknowledge within 10 working days.

11. APPENDICES

11.1 Security Baseline Quick Reference

Control	Requirement
Full-disk encryption	AES-256, all endpoints
EDR agent	Installed, active, must not be disabled
Screen lock timeout	5 minutes max
Personal cloud storage	Prohibited for work files
USB storage	Prohibited for L2+; encrypted only for L1
Passphrase min	20 characters
Password manager	Approved tool, mandatory
MFA	All accounts, no SMS
Privileged accounts	Hardware key MFA, separate daily-use account
VPN	Required all remote access to internal systems
Public Wi-Fi	VPN required before any work system access
Incident reporting	Immediate to CIRT Hotline or CISO
Security training	Annual + quarterly phishing

11.2 Approved Tools (CISO Approval Categories)

Password managers, VPN clients, authenticator apps (TOTP), cloud storage platforms, remote desktop/screen sharing, AI coding assistants/LLM tools (CISO + Engineering Lead per AZ-AI-001), communication/messaging (CISO + COO), dev environment plugins/extensions (Engineering Lead).

11.3 Legal References

Philippines: RA 10173 (Data Privacy Act 2012), RA 10175 (Cybercrime Prevention Act 2012), DICT/NPC regulations. **United States:** CFAA 18 U.S.C. § 1030, ECPA, ITAR 22 CFR Parts 120-130, EAR 15 CFR Parts 730-774, NIST CSF 2.0, NIST SP 800-53, state data breach notification laws (CCPA/CPRA).